TILBUD · OFFENTLIG ANSKAFFELSE

SAK 2026-107028

KS- og informasjonssikkerhetssystem

LEVERANDØR

Asbjørn Rørvik
Enkeltpersonforetak · org.nr 820 252 632
Vipeveien 7B, 4323 Sandnes
hei@asbjornrorvik.dev

OPPDRAGSGIVER

Antidoping Norge (ADNO)

DATO

11. mai 2026

Kvalitets- og informasjonssikkerhetssystem

Beskrivelse av kvalitetssikringssystem og informasjonssikkerhetssystem for Asbjørn Rørvik (ENK) som leverandør i kontrakten *Utvikling av antidoping-app*. Beskrivelsen oppfyller kravene i konkurransegrunnlagets pkt. 5.3.4 og er tilpasset omfanget av leveransen.

---

1. Kvalitetssikringssystem (KS)

1.1 Prinsipper

Leveransen styres etter fire prinsipper, som hver er konkret operasjonalisert:

- **Kort feedbacksløyfe** — ingen kode lever lenger enn én sprint uten å være demonstrert for ADNO.
- **Skriftlig sporbarhet** — alle beslutninger ligger i git-commit, issue-tracker eller møtereferat.
- **Automatisert kvalitet** — typesjekk, lint, tester og bygg kjøres ved hver commit. Brutt main-bransje stoppes automatisk.
- **Manuell kvalitet der det betyr noe** — UU-test, sluttbrukertester og akseptansetest er menneskelige og uavhengige.

1.2 Konkret prosess

Element	Hvordan
Kravhåndtering	Alle krav fra Bilag 1/2 mappes til issues i ADNOs git-repo. Hver issue lukkes med referanse til commit og PR.
Versjonskontroll	Git, hosted hos ADNO. Branch-modell: `main` (alltid deployable) + feature-branches via PR.
Code review	Hver PR krever gjennomlest av Asbjørn (selv-review) og automatisert sjekk. Ved større endringer engasjeres ekstern reviewer (peer fra fagnettverket) for second opinion.
Teststrategi	Unit-tester (Jest, ≥ 60 % dekning på logikk), integrasjonstester for kritiske flyter, manuell testing på minst 3 fysiske enheter (iOS + Android, ulike skjermstørrelser).
CI/CD	GitHub Actions: lint + typesjekk + tester + build på hver commit. Auto-deploy til intern test-track ved merge til `main`.
Demo og akseptanse	Demo til ADNO annenhver uke. Pilot/akseptansetest etter ca. 12 uker, før App Store/Play-publisering.
Dokumentasjon	`README.md`, `SETUP.md`, `CONTRIBUTING.md`, arkitekturdiagram og driftshåndbok i repoet. Oppdateres ved hver release.
Avvikshåndtering	Avvik registreres som issues. Kritiske avvik rapporteres til ADNO innen 24 timer skriftlig.

1.3 Kvalitetsindikatorer (mål)

- Crash-free rate i produksjon: **≥ 99,5 %**
- p95 API-responstid: **< 300 ms** for de hyppigst brukte endepunkt
- Backend oppetid (etter go-live): **≥ 99,8 %**
- Antall kritiske feil i 12-mnd garantiperiode: **0 åpne ved garantislutt**

Alle indikatorene rapporteres månedlig til ADNO i en kort statusrapport.

---

2. Informasjonssikkerhetssystem

2.1 Rammeverk

Informasjonssikkerhetsarbeidet er forankret i:

- **ISO/IEC 27001-prinsipper** (proporsjonalt anvendt for ENK med ett årsverk)
- **NSMs grunnprinsipper for IKT-sikkerhet** (versjon 2.1)
- **GDPR** og personopplysningsloven
- **OWASP Mobile Top 10** og **OWASP ASVS** for kodesikkerhet
- **App Store Review Guidelines** og **Google Play-policy**

2.2 Tiltaksoversikt

Område	Tiltak
Tilgangsstyring	Minste nødvendige tilgang. Alle kontoer har MFA. Tilgang revokeres automatisk ved avtaleslutt.
Hemmelighets-håndtering	API-nøkler, sertifikater og passord lagres kryptert i 1Password (eller ADNOs eget Key Vault). Aldri i git.
Kommunikasjons-sikkerhet	All app↔backend-trafikk kryptert med TLS 1.2+. Sertifikat-pinning aktivert i appen.
Datasikkerhet	Persondata lagres i EU/EØS. DPIA gjennomføres ved oppstart. Dataminimering — vi samler kun det som er strengt nødvendig.
Kodesikkerhet	Avhengighetsscanning (Dependabot, npm audit). Statisk analyse på CI. Manuell sikkerhetsgjennomgang før hvert App Store-release.
Endepunktsikkerhet	Utviklingsmaskin (Mac) er fullkryptert (FileVault), har MFA og automatisk skjermlås. Backup til kryptert ekstern lagring.
Logging og overvåking	Sentry for app- og backend-feil. Uptime-monitor for backend. Sikkerhetshendelser logges separat med 12 måneders retensjon.
Backup og gjenoppretting	Daglig backup av backend-database, retensjon 30 dager. Kildekoden er i seg selv kontinuerlig backup (git hos ADNO).
Hendelseshåndtering	Ved sikkerhetshendelse varsles ADNO skriftlig innen **24 timer**. Eskalering til ADNOs personvernombud og evt. Datatilsynet ved varslingsplikt.
Tredjepartsvurdering	Alle tredjepartsbiblioteker og -tjenester vurderes for risiko og dokumenteres i Bilag 10 (tredjepartsleveranser).

2.3 Personvern (særskilt)

Antidoping-appen vil håndtere informasjon om utøvere som er sensitiv av karakter (medisinske søk, fritak, kosttilskudd-spørsmål). Følgende prinsipper gjelder:

- **Dataminimering:** kun data som er nødvendig for funksjonen lagres. Søk på legemidler skjer mot Felleskatalogens API uten lagring av søkehistorikk hos ADNO.
- **Lokal lagring først:** når mulig holdes data på enheten (sjekklister, notater) og synkes ikke til skyen.
- **Ingen tredjeparts-analytics** av brukeradferd uten eksplisitt samtykke. Crash-rapporter er anonymisert (ingen brukernavn, kun teknisk stack-trace).
- **Sletting:** brukere kan slette sin konto og tilhørende data fra appen. Backend tar forespørselen til etterretning innen 30 dager.
- **Databehandleravtale (DPA):** signeres med ADNO før prosjektoppstart, jf. SSA-O Bilag 8.

2.4 Roller og ansvar

- **Sikkerhetsansvarlig hos leverandør:** Asbjørn Rørvik (innehaver). Direkte ansvar.
- **Personvernombud (ADNO):** Asbjørn samarbeider med ADNOs personvernombud i alle spørsmål om personopplysninger.
- **Underleverandør UU/test:** signerer egen taushetsplikterklæring og databehandleravtale før tilgang gis.

2.5 Revisjonsrett

ADNO har rett til årlig revisjon av leverandørens sikkerhetsarbeid relatert til denne kontrakten, jf. SSA-O Bilag 8. Leverandør stiller dokumentasjon, repo-tilgang og logger til disposisjon ved forespørsel.

3. Forbedring og evaluering

KS- og informasjonssikkerhetssystemet evalueres løpende:

- **Etter hver milepæl** i prosjektet — hva fungerte, hva må endres
- **Halvårlig sikkerhetsgjennomgang** med skriftlig rapport til ADNO i garantiperioden
- **Årlig oppdatering** av tiltaksoversikten basert på endringer i regelverk, plattformkrav (App Store / Play) og trusselbilde